

Guide d'entretien Direction / Direction Générale

Informations générales

Mission :

Date : **Heure :** **Durée prévue :** 45–60 min

Auditeur(s) présent(s) :

Interlocuteur : **Fonction :**

Preuves demandées : Politique de sécurité signée, organigramme, budget SI, rapports d'incidents

Rappel : Toute affirmation sans preuve documentaire est codée **Déclaration non corroborée** dans les papiers de travail.

Thème 1 : Gouvernance de la sécurité

#	Question	Preuve attendue
1.1	Une politique de sécurité de l'information existe-t-elle formellement ? Est-elle signée par la direction ?	Politique signée, datée
1.2	À quelle fréquence la politique est-elle révisée et mise à jour ?	Date de dernière révision
1.3	Un responsable de la sécurité est-il identifié (RSSI ou équivalent) ? Quelles sont ses attributions ?	Fiche de poste, organigramme
1.4	Les rôles et responsabilités en matière de sécurité sont-ils documentés et diffusés ?	Document de répartition des rôles

#	Question	Preuve attendue
1.5	Existe-t-il un comité ou un mécanisme formel de pilotage de la sécurité ?	PV de réunion, CR comité

Thème 2 : Budget et ressources

#	Question	Preuve attendue
2.1	Un budget spécifique est-il alloué à la sécurité de l'information ?	Extrait budget
2.2	Ce budget est-il jugé suffisant par rapport aux risques identifiés ?	Justification chiffrée
2.3	Des investissements en sécurité ont-ils été réalisés au cours des 12 derniers mois ?	Factures, bons de commande

Thème 3 : Gestion des incidents

#	Question	Preuve attendue
3.1	Des incidents de sécurité se sont-ils produits sur GIDOCEP au cours des 12 derniers mois ?	Registre des incidents
3.2	Existe-t-il une procédure formelle de gestion des incidents ?	Procédure signée
3.3	Les incidents sont-ils signalés à l'ANTIC conformément à la loi 2010/012 ?	Copie des déclarations

Thème 4 : Continuité d'activité

#	Question	Preuve attendue
4.1	Un Plan de Reprise d'Activité (PRA) existe-t-il pour GIDOCEP ?	Document PRA
4.2	Ce plan a-t-il été testé ? À quelle date ?	Rapport de test
4.3	La sauvegarde des données de GIDOCEP est-elle documentée et testée ?	Procédure de sauvegarde, log de test

Thème 5 : Conformité réglementaire

#	Question	Preuve attendue
5.1	L'organisation est-elle au fait des obligations de la loi 2010/012 ?	Registre de conformité
5.2	Des audits de sécurité ont-ils été conduits précédemment ?	Rapports d'audits antérieurs
5.3	Les recommandations des audits précédents ont-elles été traitées ?	Plan d'actions clôturé

Observations de l'auditeur :